

ESERCIZIO Creare una simulazione di un'email di phishing utilizzando ChatGPT.

Nella simulazione di una mail di phishing ho pensato di sfruttare la mia esperienza nella logistica, ho progettato una mail di phishing basata sugli acquisti online. Poiché ricevere notifiche per pacchi in arrivo o mancata consegna è diventato un gesto quotidiano, questo tipo di mail genera meno sospetti rispetto alle classiche truffe bancarie. L'idea è quella di creare un'esca meno aggressiva, ma più credibile e nuova, capace di ingannare anche l'utente più attento.

Come primo prompt richiesto a CHATGPT è stato: sto facendo un corso di cyber sicurezza, e sono arrivato allo studio della fase di phishing, devo creare una mail per simulare un finto attacco di spam. Oltre alle classiche mail di spam già conosciute quale mail di esca consigli?

Tale prompt viene effettuato per avere una visione più ampia possibile su tutti gli attacchi possibili

Questa è la risposta fornita dall'IA che ha indicato 8 possibili scenari:

Per una simulazione didattica di phishing (ambito formazione/cyber-security), è utile andare oltre le classiche “hai vinto un premio” e usare esche verosimili, coerenti con contesti reali. Di seguito trovi tipologie di mail-esca efficaci, con obiettivo, leva psicologica e indicatori di rischio. Evito testi pronti all'uso: servono a studiare e riconoscere il pattern, non a replicare attacchi reali.

1) Finta comunicazione IT aziendale

Contesto: ambiente corporate

Leva: autorità + urgenza

Scenario: “Aggiornamento sicurezza / reset password”

Segnali tipici

- Mittente simile al dominio interno (typosquatting)
- Invito ad “agire entro X ore”
- Link a portale login non aziendale

2) Avviso di accesso sospetto

Contesto: servizi cloud / email / VPN

Leva: paura + protezione dell'account

Scenario: “Tentativo di accesso da nuova posizione”

Segnali tipici

- IP o località generica (“Europa dell'Est”)

- CTA unica (“Verifica ora”)
 - URL accorciato o dominio simile all’originale
-

3) Finta fattura o documento condiviso

Contesto: contabilità / HR / fornitori

Leva: routine lavorativa

Scenario: “Fattura in sospeso / Documento condiviso”

Segnali tipici

- Allegati .html, .zip, .iso o link a cloud anonimo
 - Oggetto neutro, non allarmistico
 - Firma incompleta o incoerente
-

4) Comunicazione da corriere / spedizione

Contesto: privati e aziende

Leva: aspettativa (pacchi frequenti)

Scenario: “Consegna non riuscita / dazi doganali”

Segnali tipici

- Richiesta micro-pagamento
 - Tracking non verificabile
 - Errori minimi nel brand (logo, colori, dominio)
-

5) Finta comunicazione HR / amministrazione

Contesto: buste paga, ferie, rimborsi

Leva: interesse personale

Scenario: “Aggiornamento busta paga / rimborso”

Segnali tipici

- Richiesta credenziali o dati bancari
 - Linguaggio formale ma generico
 - Link esterno invece di portale interno
-

6) Invito a riunione o firma documento

Contesto: smart working

Leva: pressione sociale

Scenario: “Firma urgente / Meeting aggiornato”

Segnali tipici

- Finti servizi di e-signature
 - Allegati con macro
 - Orari incoerenti o mittente esterno
-

7) Finto ente pubblico o servizio essenziale

Contesto: tasse, sanità, utenze

Leva: autorità + conseguenze

Scenario: “Comunicazione obbligatoria”

Segnali tipici

- Minacce di sanzioni
 - Linguaggio burocratico impreciso
 - URL non istituzionale
-

8) Notifica di violazione dati (data breach)

Contesto: piattaforme note

Leva: panico

Scenario: “I tuoi dati sono stati compromessi”

Segnali tipici

- Richiesta immediata di cambio password via link
- Nessun riferimento personalizzato
- Dominio clone

Negli 8 scenari forniti dall'IA è presente anche quello che avevo individuato per tanto ho deciso di creare una mail di phishing per risalire a dati sensibili degli utenti.

Scenario creato

Contesto:

Email che sembra provenire da un corriere di spedizioni. Il messaggio informa che un pacco non è stato consegnato a causa di indirizzo errato o incompleto.

Obiettivo del phishing:

Indurre la vittima a fornire dati personali:

- nome e cognome
- indirizzo completo
- numero di telefono
- indirizzo email

Queste informazioni possono essere usate per:

- furto d'identità
- phishing mirato (spear phishing)
- rivendita dei dati
- ulteriori truffe (smishing / vishing)

Perché questo scenario è efficace:

Molti utenti:

- attendono realmente pacchi
- ricevono spesso comunicazioni dai corrieri
- tendono a reagire rapidamente per non perdere la consegna

Come secondo prompt ho chiesto a CHAT di crearmi una mail relativa al punto 4) Comunicazione da corriere / spedizione

Allego la risposta fornita:

Subject: ☐ Consegna sospesa – azione richiesta entro 24 ore

Gentile Cliente,

non siamo riusciti a completare la consegna del tuo pacco **n. TRK-55892104** a causa di **informazioni incomplete sull'indirizzo**.

☐ **Stato spedizione:** In attesa di conferma

 **Tempo limite:** 24 ore dalla ricezione di questa email

Per evitare la **restituzione automatica al mittente**, ti chiediamo di **verificare immediatamente i dati di consegna** tramite il link seguente:

☐ [https://tracking-update-corriere24\[.\]info/verifica](https://tracking-update-corriere24[.]info/verifica)

Se la procedura non verrà completata entro il tempo indicato, il pacco sarà **annullato** e potrebbero essere applicati **costi aggiuntivi di gestione**.

Nota: in alcuni casi può essere richiesto un **piccolo contributo di 1,99 €** per la nuova programmazione della consegna.

Grazie per la collaborazione,
Servizio Clienti Corriere24

Questo messaggio è stato inviato automaticamente, si prega di non rispondere.
Corriere24 © 2026 Tutti i diritti riservati

Perché l'email può sembrare credibile

1. **Contesto realistico**
 - Le notifiche di corrieri sono frequenti.
 - L'utente medio aspetta spesso pacchi e abbassa la soglia di attenzione.
2. **Problema plausibile**
 - “Indirizzo incompleto” è un errore comune e non immediatamente sospetto.
 - Non richiede spiegazioni tecniche complesse.
3. **Tono formale ma semplice**
 - Linguaggio simile a comunicazioni automatiche reali.
 - Nessun allarmismo eccessivo, solo pressione moderata.
4. **Presenza di dettagli concreti**
 - Stato spedizione e tempistica definita.
5. **Richiesta economica minima**
 - Importo basso (1,99 €) → riduce la percezione di rischio.
 - Spesso associato a “spese di gestione” reali (i dazi o eventuali contrassegni)
6. **Firma e footer**
 - “Messaggio automatico / non rispondere” è coerente con sistemi reali.
 - Uso di termini come “Servizio Clienti”.

Elementi che fanno scattare il campanello d'allarme

1. Dominio del link

- Non corrisponde a un dominio ufficiale di un corriere noto.
- Uso di termini generici: `tracking`, `update`, `corriere24`.
- Dominio recente o sconosciuto → red flag forte.

2. Urgenza artificiale

- “Entro 24 ore” senza reale giustificazione tecnica.
- Minaccia di annullamento automatico → pressione psicologica.

3. Genericità del destinatario

- Nessun riferimento a dati personali verificabili (numero di spedizione corretto, eventuali reali importi da pagare)

4. Incoerenza comunicativa

- Un corriere non chiede quasi mai la conferma indirizzo via link esterno.
- Normalmente rimanda all’area clienti ufficiale o all’app.

5. Richiesta di pagamento tramite link:

- Qualsiasi richiesta di denaro via email è sospetta.
- I corrieri gestiscono pagamenti solo su piattaforme ufficiali/app.

6. Errori linguistici e stilistici

- Piccole imprecisioni grammaticali o lessicali.
- Frasi poco naturali o tradotte (“nuova programmazione”).

7. Assenza di canali alternativi

- Nessun numero di assistenza reale.
- Nessun riferimento verificabile (sede legale, P. IVA, PEC).

CONCLUSIONE

Questa simulazione mostra come un’email di phishing possa sembrare credibile perché sfrutta situazioni comuni, urgenza e messaggi semplici. Allo stesso tempo, piccoli segnali come link sospetti, richieste di pagamento, genericità del testo ed errori formali sono sufficienti per individuare la minaccia.